

Clase 202 — El ciclo de respuesta a incidentes (NIST y SANS)

Parte: **9 — Forense digital y respuesta a incidentes** · Fuente: *NIST SP 800-61 Rev. 2 — Computer Security Incident Handling Guide* · Duración estimada: **90 min** · Nivel: **Fundamentos**

Objetivo

Dominar los dos marcos de referencia que estructuran toda respuesta a incidentes: el ciclo de cuatro fases de **NIST SP 800-61** y el modelo **PICERL** de SANS de seis pasos. Al terminar sabrás en qué fase estás durante un incidente real, qué actividades corresponden a cada una y cómo evitar saltar pasos bajo presión.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

- 1. **Describir** las cuatro fases del ciclo NIST y su carácter iterativo.
- 2. **Mapear** el modelo PICERL de SANS contra las fases de NIST.
- 3. **Clasificar** un evento como incidente y asignarle severidad.
- 4. **Definir** los criterios de activación y de cierre de un incidente.
- 5. **Construir** un runbook mínimo para una fase concreta.

Temas

#	Tema	Por qué importa
1	Ciclo NIST de 4 fases	Estructura oficial de referencia
2	Preparación	El 80% del éxito se juega antes
3	Detección y análisis	Distinguir ruido de incidente real
4	Contención, erradicación y recuperación	El núcleo de la respuesta
5	Actividad post-incidente	Sin lecciones, se repite el error
6	Modelo PICERL de SANS	La variante mnemotécnica más usada
7	Clasificación y severidad	Prioriza recursos escasos
8	Roles y comunicación	Evita el caos organizativo

Definiciones y características

- **Evento vs. incidente:** un evento es cualquier ocurrencia observable; un incidente es un evento que viola (o amenaza) la política de seguridad. Característica: no todo evento escala.

- **Preparación:** fase donde se crean equipos, herramientas, contactos y procesos antes de que ocurra nada. Característica: es continua, no un hito.
- **Detección y análisis:** identificación y validación del incidente, determinación de alcance. Característica: aquí se decide si se activa el resto.
- **Contención:** limitar la propagación. Característica: puede ser a corto (aislar) o largo plazo (parcheo temporal).
- **Erradicación:** eliminar la causa (malware, cuentas comprometidas, vulnerabilidad). Característica: incompleta si queda persistencia.
- **Recuperación:** volver a operación normal con monitoreo reforzado. Característica: gradual y verificada.
- **PICERL:** Preparation, Identification, Containment, Eradication, Recovery, Lessons Learned. Característica: mnemónico de SANS equivalente al ciclo NIST.

Herramientas y preparación

- **Marcos:** descarga NIST SP 800-61 Rev. 2 y el *Incident Handler's Handbook* de SANS.
- **Plantillas:** una matriz de severidad (P1–P4), una plantilla de runbook y una lista de contactos de escalado.
- **Software de apoyo:** un sistema de tickets (TheHive es ideal y gratuito) para registrar el ciclo de vida del incidente.

Laboratorio guiado

Ejercicio aplicado de proceso. No requiere entorno ofensivo.

1. Define una **matriz de severidad** con cuatro niveles. Para cada uno especifica: impacto, tiempo de respuesta objetivo y quién debe ser notificado.
2. Toma este escenario: "El EDR reporta que un servidor de nóminas ejecutó PowerShell ofuscado que contactó una IP externa a las 03:14 UTC". Clasifícalo y justifica la severidad.
3. Recorre las cuatro fases NIST anotando, para este caso, al menos dos acciones concretas por fase.
4. Traduce esas acciones al esquema PICERL y verifica que no falte ninguna.
5. Redacta un **runbook** de la fase de contención para este caso: pasos numerados, decisión de "aislar vs. observar", y quién autoriza.
6. Define los **criterios de cierre**: ¿qué debe cumplirse para declarar el incidente resuelto? Documenta al menos cuatro.
7. Registra todo el ciclo como un ticket en TheHive (o en una tabla si no lo tienes instalado).

Ejercicios

1. Dibuja el ciclo NIST como diagrama y marca dónde es iterativo.
2. Crea una tabla que mapee cada paso PICERL con su fase NIST equivalente.
3. Define cinco criterios que convierten un "evento" en "incidente".
4. Diseña una matriz de severidad P1–P4 para una PYME.
5. Escribe el runbook de detección para alertas de phishing reportadas por usuarios.
6. Analiza un caso donde saltarse la contención antes de la erradicación empeoró las cosas.

Reto verificable

Elabora un runbook completo de respuesta para un caso de ransomware en un endpoint, cubriendo las seis etapas de PICERL con acciones concretas, responsables y criterios de transición entre etapas.

Criterio de aceptación: el runbook tiene las seis etapas, cada una con al menos tres acciones numeradas, un responsable asignado y una condición explícita para pasar a la siguiente etapa. Un compañero debe poder ejecutarlo sin preguntarte nada.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
El equipo erradica sin contener	Se saltó una fase por prisa; el malware se reinfecta. Respeta el orden PICERL.
Todos los incidentes son "críticos"	Falta matriz de severidad. Define criterios objetivos por nivel.
Nadie sabe a quién avisar	No hay lista de escalado. Créala en preparación.
El incidente "nunca cierra"	Sin criterios de cierre. Defínelos por adelantado.
Se repite el mismo ataque	Se omitió la fase de lecciones aprendidas. Hazla obligatoria.

Preguntas frecuentes

? ¿NIST o SANS, cuál uso? Son compatibles. NIST es la referencia formal; PICERL es el mnemónico operativo. Muchos equipos usan PICERL para comunicar y NIST para documentar.

? ¿La preparación es una sola vez? No, es continua: cada incidente alimenta mejoras a la preparación.

? ¿Puedo contener y erradicar a la vez? A veces se solapan, pero conceptualmente contiene primero para no perder evidencia ni alertar al atacante prematuramente.

? ¿Qué diferencia hay entre contención a corto y largo plazo? Corto: aislar el equipo ya. Largo: solución temporal estable (segmentar red, regla de firewall) mientras se erradica.

Referencias

- NIST SP 800-61 Rev. 2: <https://csrc.nist.gov/publications/detail/sp/800-61/rev-2/final>
- SANS — *Incident Handler's Handbook*: <https://www.sans.org/white-papers/33901/>
- TheHive Project: <https://thehive-project.org/>
- Roberts & Brown — *Intelligence-Driven Incident Response*, O'Reilly 2017.

Siguiendo clase

Clase 203 - Adquisición forense: discos e imágenes